

支付漏洞



01

支付漏洞





支付原理

在业务安全方面，支付原理主要涉及到支付过程中的身份验证、风险控制和交易保障等方面。具体来说，支付机构通常会采用多种手段来确保支付过程的安全性，例如：

身份验证：支付机构会对买家和卖家的身份进行验证，以确保只有合法的用户才能进行交易。

风险控制：支付机构会对交易进行风险评估，并采取相应的措施来防范欺诈和非法交易等风险。

交易保障：支付机构会提供交易保障服务，例如交易纠纷处理、退款等服务，以确保用户的权益得到保障。



支付漏洞原理

支付漏洞通常是指在一个应用程序或网站的支付流程中存在漏洞，可能导致支付信息被恶意利用或导致金钱损失。以下是一些常见的支付漏洞原理：

不正确的输入验证： 支付流程通常涉及到用户提供的输入，如金额、银行卡号、付款地址等。例如，攻击者可能提交负数金额，或者使用非法的银行卡信息。

重放攻击： 在某些情况下，攻击者可以截获支付请求并多次重放它们，导致多次扣款。这通常发生在通信不加密或不安全的情况下。

价格篡改： 攻击者可能尝试篡改购物车中的价格或商品数量，以获得更低的价格或额外的商品。



支付漏洞原理

交易注入： 如果应用程序的支付请求构造不当，攻击者可能尝试注入恶意代码或恶意请求，以执行未经授权的支付。

缺乏双因素认证： 如果支付流程没有双因素认证，攻击者可能只需知道用户的密码就能够进行支付。更安全的支付系统应该要求多个身份验证步骤，如密码加上手机验证码。

不安全的第三方支付集成： 如果应用程序集成了第三方支付服务，但没有正确处理响应或错误情况，攻击者可能会通过模拟支付来欺骗应用程序。

社会工程学和钓鱼： 攻击者可能试图通过欺骗用户来获取其支付信息，例如通过伪装成可信的实体或发送恶意电子邮件。



支付漏洞绕过思路

1.修改支付价格

2.修改支付状态

3.修改购买数量

4.修改附属值-运费

5.修改支付接口

6.多重替换支付

7.重复支付

8.最小额支付

9.值为最大值支付问题

10.越权支付

11.无限制试用

12.多线程并发



1.修改支付价格

在支付当中，购买商品一般分为三步骤：订购、确认信息、付款。

那么这个修改价格具体是修改哪一步时的价格呢？

在我看来，你可以在这三个步骤当中的随便一个步骤进行修改价格测试，
如果前面两步有验证机制，那么你可在最后一步付款时进行抓包尝试修改金额，
如果没有在最后一步做好检验，
那么问题就会存在，其修改的金额值你可以尝试小数目或者尝试负数。



2.修改支付状态

存在可修改订单状态的接口，比如确认收货接口，确认收货以后订单状态会变成“已完成”。

有如下接口/setorderstatus?orderid=1093&orderstatus=3

orderstatus=1待支付， orderstatus=2已支付， orderstatus=3已完成。

利用上述接口，可直接将待支付的订单状态改成已支付。

01

支付漏洞



3.修改购买数量

	宝家洁自动拧水魔术平板拖超值组 颜色/尺码：宝家洁自动拧水魔术平板拖超值组共同共同 货号：20119526	¥199.00	-1	免费
	兔之力管道疏通清洁超值组 颜色/尺码：兔之力管道疏通清洁超值组共同共同 货号：20115058	¥199.00	1	免费

添加订单备注信息：

请勿填写与支付，收货，发票相关的信息

微客服推荐码：

☐ 使用积分 账户可用积分 1001 可抵扣 10.01元

☐ 使用礼品卡券 礼品卡券总价值 0元 礼品卡充值

☐ 我的折价券(特惠商品海量商品不能使用)

商品总计：0.00 元 + 运费：0.00 - 优惠：-10.00元

应付总额：10.00元



01 支付漏洞



4.修改附属值

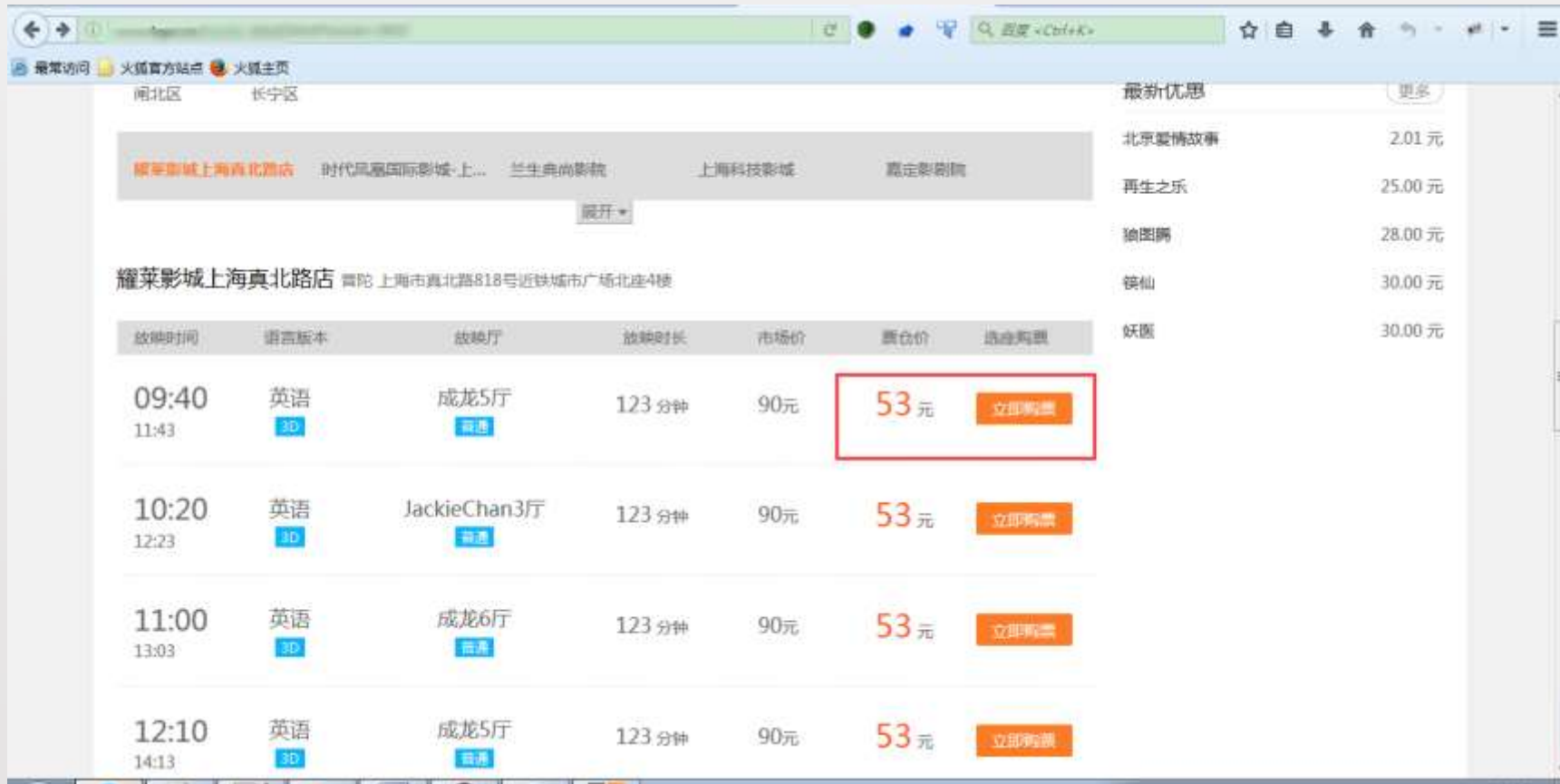
1、修改优惠券金额

2、修改积分金额

3、修改运费金额

4.修改附属值

1) 修改服务费金额



耀莱影城上海真北路店 时代晶宫国际影城·上... 兰生典尚影院 上海科技影城 嘉定影剧院

耀莱影城上海真北路店 普陀 上海市真北路818号近铁城市广场北座4楼

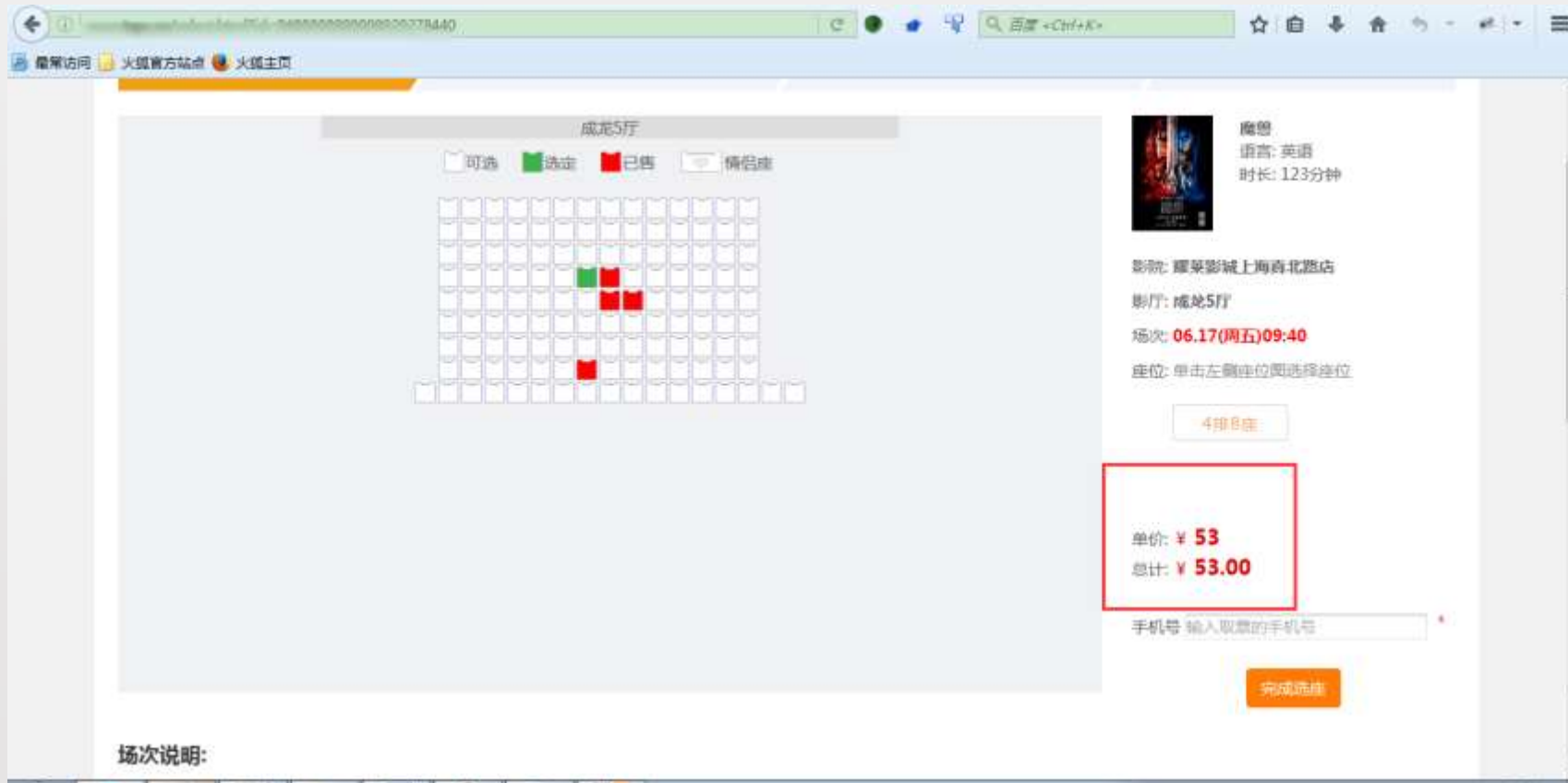
放映时间	语言版本	放映厅	放映时长	市场价	票价	选座购票
09:40 11:43	英语 3D	成龙5厅 普通	123 分钟	90元	53元	立即购买
10:20 12:23	英语 3D	JackieChan3厅 普通	123 分钟	90元	53元	立即购买
11:00 13:03	英语 3D	成龙6厅 普通	123 分钟	90元	53元	立即购买
12:10 14:13	英语 3D	成龙5厅 普通	123 分钟	90元	53元	立即购买

最新优惠

北京爱情故事	2.01 元
再生之乐	25.00 元
瑜图麟	28.00 元
镜仙	30.00 元
妖医	30.00 元

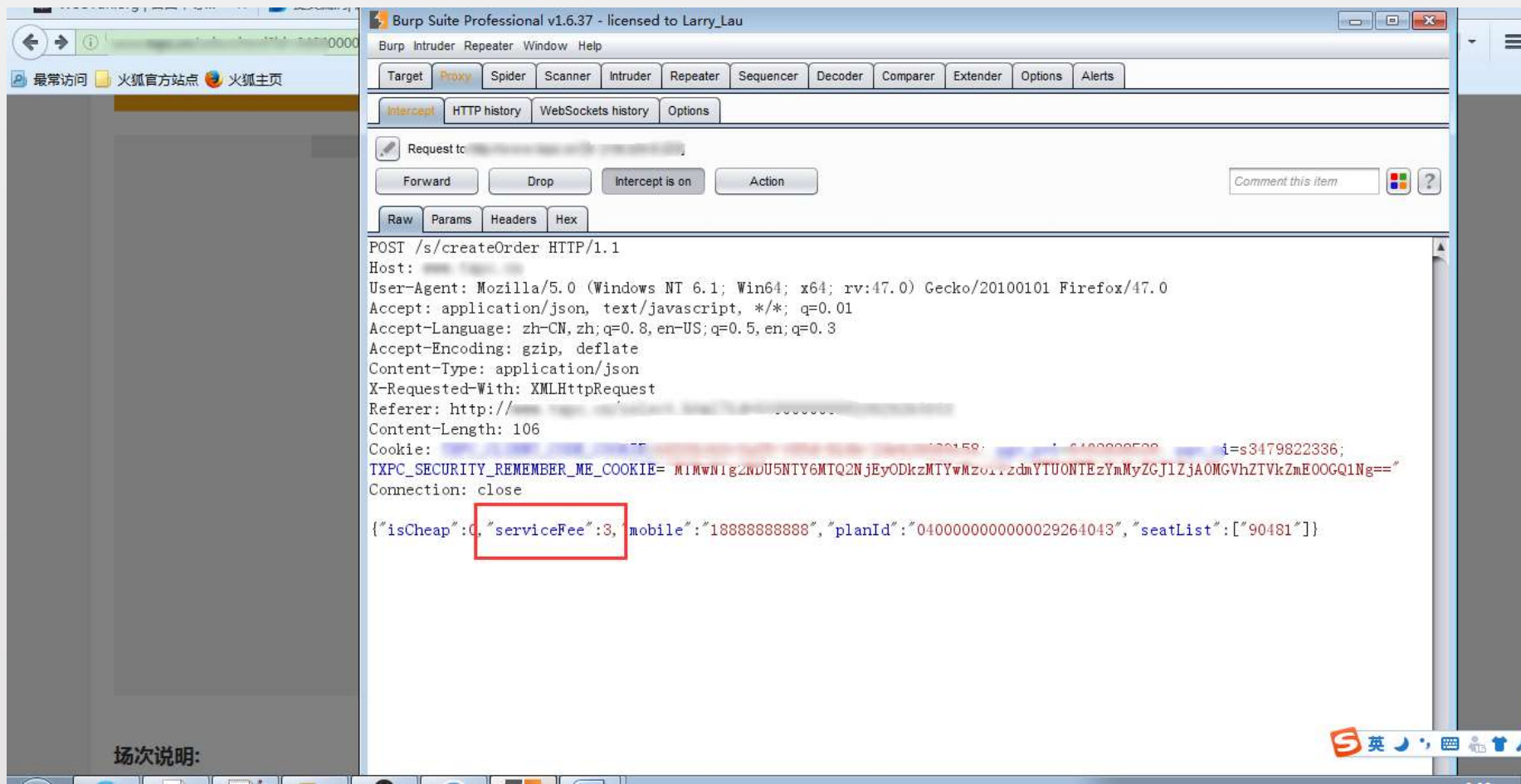
4.修改附属值

1) 修改服务费金额



4.修改附属值

1) 修改服务费金额



01 支付漏洞

4.修改附属值

1) 修改服务费金额

The screenshot shows the Burp Suite Professional interface. The main window displays an intercepted HTTP request. The request is a POST to the endpoint `/s/createOrder`. The request body is a JSON object. The `serviceFee` field is highlighted with a red box, indicating the target for modification.

```
POST /s/createOrder HTTP/1.1
Host: ...
User-Agent: Mozilla/5.0 (Windows NT 6.1; Win64; x64; rv:47.0) Gecko/20100101 Firefox/47.0
Accept: application/json, text/javascript, */*; q=0.01
Accept-Language: zh-CN, zh; q=0.8, en-US; q=0.5, en; q=0.3
Accept-Encoding: gzip, deflate
Content-Type: application/json
X-Requested-With: XMLHttpRequest
Referer: http://...
Content-Length: 106
Cookie: ... pgv_pvi=6402838528; pgv_si=s3479822336;
TXPC_SECURITY_REMEMBER_ME_CO... 3NDJkNzU3NjJlMTF1ZGUyYjJlMDg3Ng=="
Connection: close

{"isCheap":0,"serviceFee":-49.99,"mobile":"18888888888","planId":"0400000000000029264043","seatList":["90481"]}
```

01 支付漏洞

4.修改附属值

1) 修改服务费金额

The screenshot shows a web browser window displaying a movie booking confirmation page. The page has a navigation bar with links for '首页' (Home), '电影' (Movies), '影院' (Theaters), '资讯' (News), and '活动' (Activities). Below the navigation bar is a progress bar with four steps: '1.选择影片场次' (Select movie and showtime), '2.在线选座 填写手机号码' (Online seat selection and fill in mobile number), '3.确认订单 支付' (Confirm order and pay), and '4.终端机取票' (Terminal ticket collection). The current step is '3.确认订单 支付'. The main content area is titled '确认订单信息' (Confirm order information). It displays the following details:

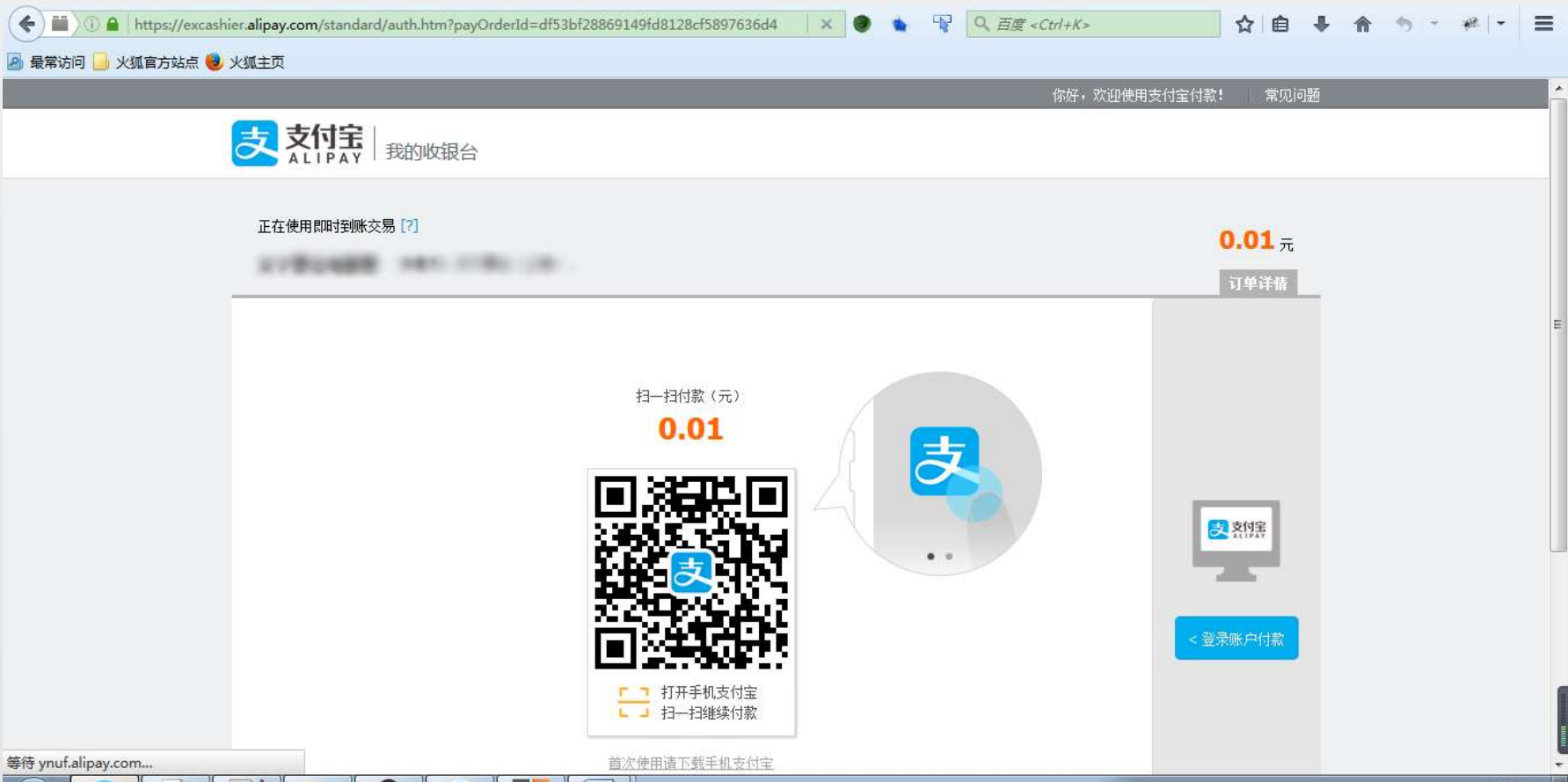
	影片: 魔兽 3D	语言版本: 英语
	影院: 耀莱影城上海真北路店	放映影厅 JackieChan3厅
	场次: 06.17(周五)12:50	
	座位: 5排7座	
金额: 0.01 (50.00元 * 1张, 服务费-49.99元 / 张)		

 A red box highlights the '金额' (Amount) field, showing '0.01' instead of the expected '50.00'. To the right of the order details, there is a warning box: '请在15分钟内完成付款, 否则系统将自动释放已选座位' (Please complete payment within 15 minutes, otherwise the system will automatically release the selected seats). Below this, it shows '剩余支付时间: 14分47秒' (Remaining payment time: 14 minutes 47 seconds) and '客服电话: 400-607-5588' (Customer service phone: 400-607-5588). At the bottom, there is a section for '使用兑换券支付' (Use coupon to pay) with a button labeled '+ 使用优惠券或兑换卷' (Use coupon or exchange coupon). The browser's address bar shows '百度 <Ctrl+K>' and the page title is '火狐官方网站' (Firefox Official Website).



4.修改附属值

1) 修改服务费金额



4.修改附属值

2) 修改运费价格

当前位置： 首页 > 购物商城 > 手机数码 > 手机通讯



iPhone 6 Plus

支持联通移动通信三网4G, 5.5英寸, 1920x1080分辨率, 800万像素摄像头, Touch ID指纹识别传感器

货号 SD7159810321

市场价 ¥6388.00

销售价 **¥5780.00**

购买数量 库存997126件

[立即购买](#) [加入购物车](#)

分享到： [腾讯](#) [新浪](#) [人人网](#) [邮件](#) [网址](#) [更多](#)



4.修改附属值

2) 修改运费价格

3、配送方式

☒

顺丰快递 费用：0.00元

4、商品清单

商品信息	单价	优惠(元)	数量	金额(元)	积分	库存(件)
 iPhone 6 Plus	¥ 5780.00	¥ 0.00	1	¥ 5780.00	+ 200	997126

5、结算信息

☐ 是否开具发票

订单备注(100字符以内)

商品 1 件 商品金额：¥5780.00 元 总积分：200 分

运费：¥0.00 元 + 支付手续费：¥0.00 元 + 税费：¥0.00 元

应付总金额：¥5780.00

返回购物车

确认提交

4.修改附属值

2) 修改运费价格

```
POST /tools/submit_ajax.ashx?action=order_save&site_id=1 HTTP/1.1
Host: 192.168.10.205
Content-Length: 406
Accept: application/json, text/javascript, */*; q=0.01
Origin: http://192.168.10.205
X-Requested-With: XMLHttpRequest
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_14_5) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/75.0.3770.142 Safari/537.36
Content-Type: application/x-www-form-urlencoded; charset=UTF-8
Referer: http://192.168.10.205/shopping.html
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
Cookie: ASP.NET_SessionId=ykkjxwcv1qhg35ynxrmu4l2; dt_cookie_url_referrer=%2fuser%2fcenter%2findex.html;
dt_cookie_user_name_remember=DTcms=test123; dt_cookie_user_pwd_remember=DTcms=8887F2EC2DC621B9;
dt_cookie_shopping_buy=%5b%7b%22channel_id%22%3a%22c+%22article_id%22%3a%22c+%22quantity%22%3a%22d%5d
Connection: close

book_id=0&accept_name=%E5%BC%A0%E4%B8%89&province=%E5%A4%A9%E6%B4%A5%E5%B8%82&city=%E5%B8%82%E8%BE%96%E5%8C%BA&area=%E6%B2%B
3%E4%B8%9C%E5%8C%BA&address=%E5%90%88%E8%82%A5%E5%A4%A7%E9%81%93%51%E5%8F%B7&mobile=13112345678&telephone=13112345678&email=11
1%40qq.com&post_code=&payment_id=1&payment_price=0.00&payment_price=0.00&payment_price=0.00&express_id=1&express_price=0.00&
taxAmount=4&invoice_title=&message=
```



4.修改附属值

2) 修改运费价格

```
POST /tools/submit_ajax.ashx?action=order_save&site_id=1 HTTP/1.1
Host: 192.168.10.205
Content-Length: 406
Accept: application/json, text/javascript, */*; q=0.01
Origin: http://192.168.10.205
X-Requested-With: XMLHttpRequest
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_14_5) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/75.0.3770.142 Safari/537.36
Content-Type: application/x-www-form-urlencoded; charset=UTF-8
Referer: http://192.168.10.205/shopping.html
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
Cookie: ASP.NET_SessionId=ykkjxwcv1qhg35ynxrmu4l2; dt_cookie_url_referrer=%2fuser%2fcenter%2findex.html;
dt_cookie_user_name_remember=DTcms=test123; dt_cookie_user_pwd_remember=DTcms=8887F2EC2DC621B9;
dt_cookie_shopping_buy=%5b%7b%22channel_id%22%3a2%2c+%22article_id%22%3a88%2c+%22quantity%22%3a1%7d%5d
Connection: close

book_id=0&accept_name=%E5%BC%A0%E4%B8%89&province=%E5%A4%A9%E6%B4%A5%E5%B8%82&city=%E5%B8%82%E8%BE%96%E5%8C%BA&area=%E6%B2%B3%E4%B8%9C%E5%8C%BA&address=%E5%90%88%E8%82%A5%E5%A4%A7%E9%81%9351%E5%8F%B7&mobile=13112345678&telephone=13112345678&email=111%40qq.com&post_code=&payment_id=1&payment_price=0.00&payment_price=0.00&payment_price=0.00&express_id=1&express_price=-10000.00&taxAmount=4&invoice_title=&message=
```



01 支付漏洞



4.修改附属值

2) 修改运费价格

交易订单

已关闭订单

[返回](#)

订单号	订单商品	姓名	订单金额	下单时间	状态	操作
B19072823193372		张三	¥ -4220.00 货到付款	2019/7/28 23:19:33	待确认	查看订单 取消

4.修改附属值

2) 修改运费价格

查看订单

返回

下单

确认

发货

完成

2019/7/28 23:19:33

订单号: B19072823193372

订单状态: 待确认

商品信息

单价

积分

数量

金额

积分



iPhone 6 Plus☆flag{B8F4B478-304F-4BA7-91AF-E9675D4AB565}

~~¥5780.00~~
¥ 5780.00

+ 200

1

¥ 5780.00

200

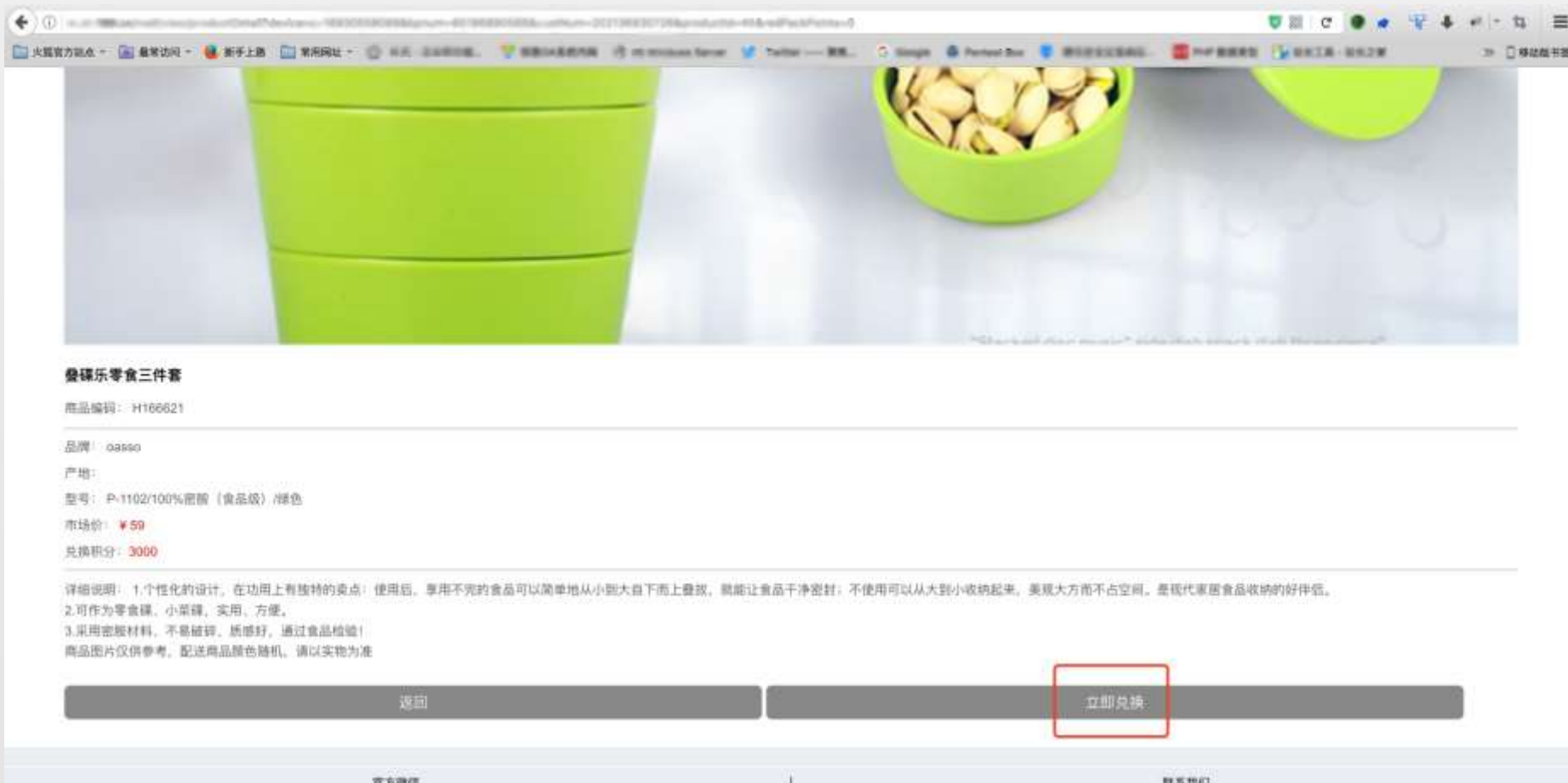
商品金额: ¥ 5780.00 + 运费: ¥ -10000.00 + 支付手续费: ¥ 0.00 税费: 0.00

应付总金额: ¥ -4220.00



4.修改附属值

3) 修改积分



叠碟乐零食三件套

商品编码: H106621

品牌: oasso

产地:

型号: P-1102/100% 聚丙烯 (食品级) /绿色

市场价: ¥59

兑换积分: 3000

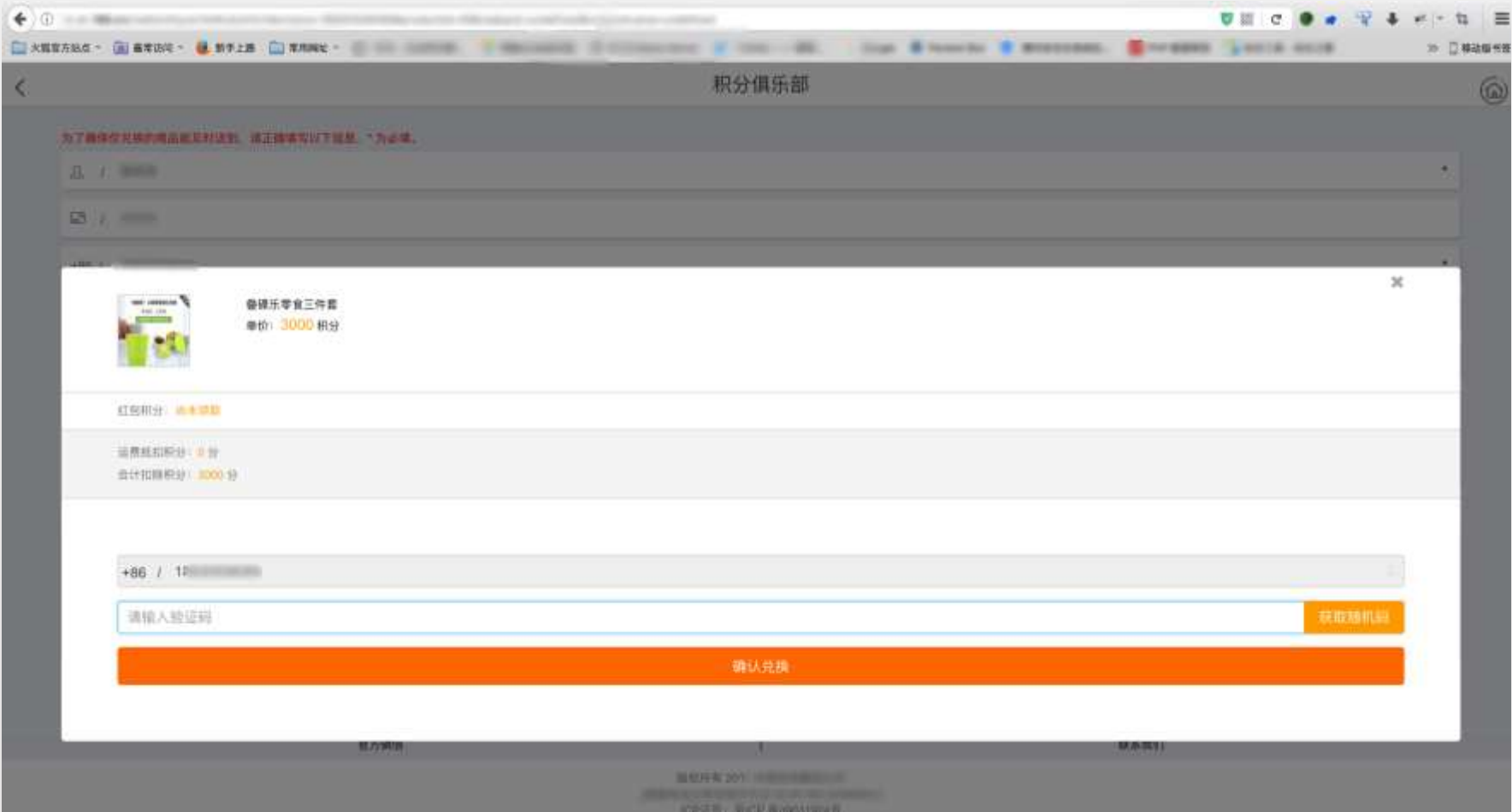
详细说明: 1.个性化的设计,在功用上有独特的卖点:使用后,享用不完的食品可以简单地从小变大自上而下叠放,就能让食品干净密封;不使用可以从大到小收纳起来,美观大方而不占空间,是现代家居食品收纳的好伴侣。
2.可作为零食碟、小果碟,实用、方便。
3.采用密胺材料,不易破碎,质感好,通过食品检验!
商品图片仅供参考,配送商品颜色随机,请以实物为准

返回 立即兑换

官方微信 | 联系我们

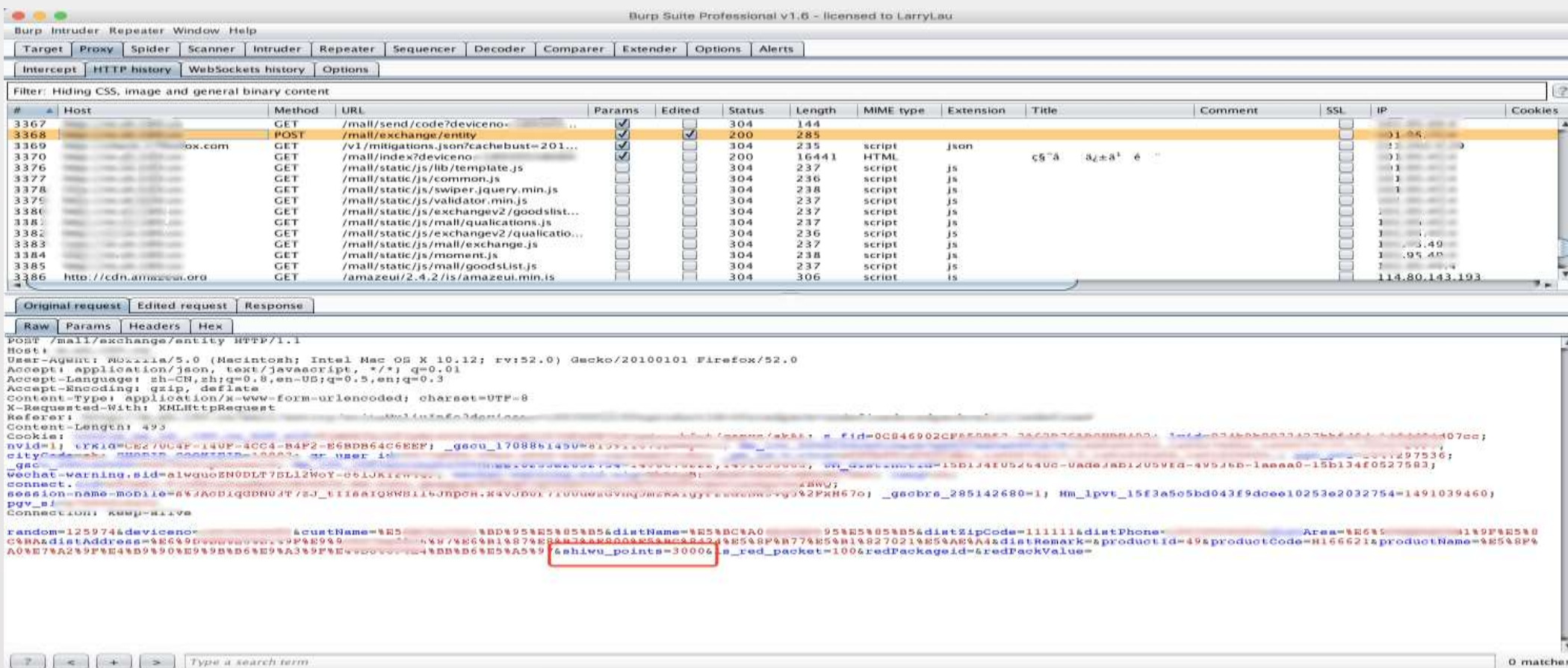
4.修改附属值

3) 修改积分



4.修改附属值

3) 修改积分



01 支付漏洞

4.修改附属值

3) 修改积分





4.修改附属值

3) 修改积分

【██████████】尊敬的客户，您在██████████渠道兑换了叠碟乐零食三件套商品，订单号是██████████，扣除总积分100，剩余可用积分2464，请登录██████████官方网站(<http://██████████>)、使用██████████客户端查询积分信息。██████████公司]



5.修改支付接口

比如一些网站支持很多种支付，比如自家的支付工具，第三方的支付工具，然后每个支付接口值不一样，如果逻辑设计不当，当我随便选择一个点击支付时进行抓包，然后修改其支付接口为一个不存在的接口，如果没做好不存在接口相关处理，那么此时就会支付成功。



6.多重替换支付

首先去产生两个订单，这两个订单商品是不一样的，其价格不一样，如果服务端没有做好这相关的验证，那么在支付的过程当中抓包，修改其订单值为另一个订单值，最后支付，这时就可以用订单一的支付价格买到订单二的商品。



7.重复支付

比如订单支付会返现，或者返积分。

重复调用支付成功回调的接口，可实现多次返现，或多次返积分。



8.最小额支付

这个问题如果你在充值时进行修改其支付金额为负数或者0.01等是会显示支付失败的，但是如果你修改其金额为1.00，那么支付就会成功。

这里最低就是1元，1元对应100积分，而你如果修改为0.01，那么对应的积分就是空值了，所以会显示失败，而当你修改为1元，那么1元这个支付接口是存在的，其后面积分分数为其它金额的积分数，然后跳转过去支付就会以1元购买到比它多得多的积分数量，也可以是任意积分值。



支付漏洞



10.越权支付

现在可能很少存在这类问题，在支付当中会出现当前用户的ID，比如：
username=XXXXX，如果没有加以验证，其支付也是一次性支付没有要求输入密码什么的机制，那么就可以修改这个用户ID为其它用户ID，达到用其他用户的账号进行支付你的商品。



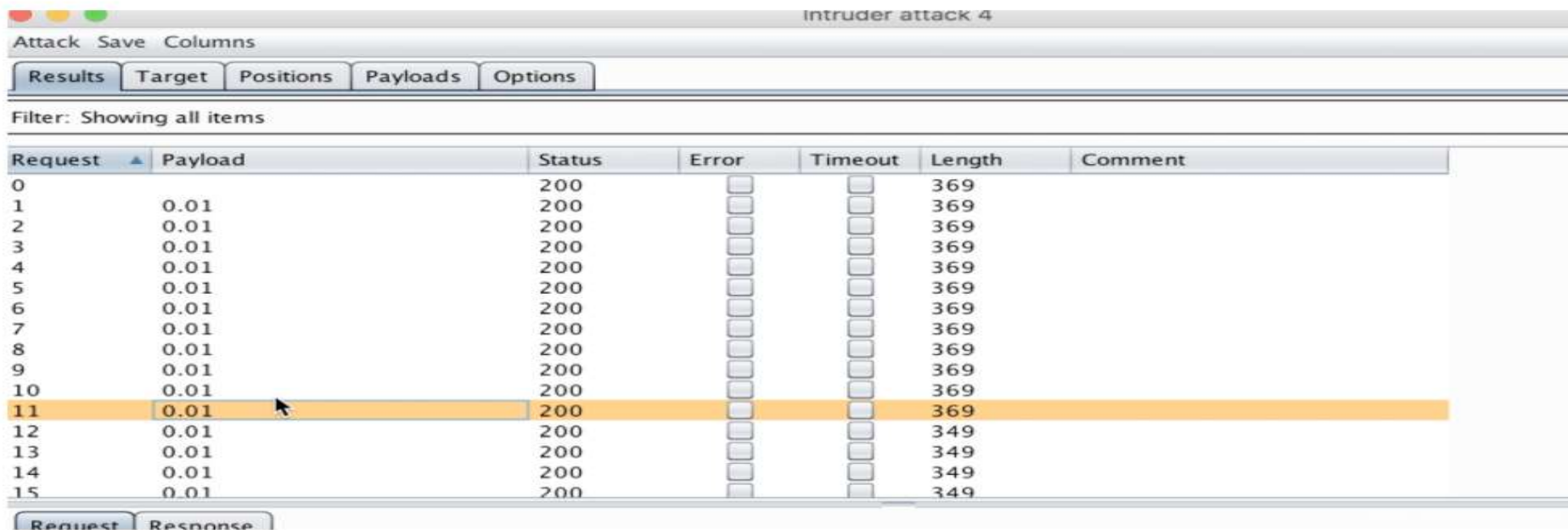
11.无限制试用

一些网站的一些商品，比如云系列产品支持试用，试用时期一般为7天或者30天，一个账户只能试用一次，试用期间不能再试用，但如果这个试用接口会做好分配那么很容易导致问题的发生。

比如：在支付的时候它URL后面的支付接口是3，而试用接口是4，那么此时你已经试用过了，复制下确认试用时的URL，修改后面的支付接口为3，那么此时就会调用购买支付接口，但是由于你本身这个产品就是试用的，其相应值绑定了这个试用商品，那么金额就肯定是0，那么最后点击支付，你就可以看到支付成功，试用成功，又重复试用了一次，然后他们的试用时间会累加在一起，这就导致了可无限制购买任何产品了。



12.多线程并发



Request	Payload	Status	Error	Timeout	Length	Comment
0		200	☐	☐	369	
1	0.01	200	☐	☐	369	
2	0.01	200	☐	☐	369	
3	0.01	200	☐	☐	369	
4	0.01	200	☐	☐	369	
5	0.01	200	☐	☐	369	
6	0.01	200	☐	☐	369	
7	0.01	200	☐	☐	369	
8	0.01	200	☐	☐	369	
9	0.01	200	☐	☐	369	
10	0.01	200	☐	☐	369	
11	0.01	200	☐	☐	369	
12	0.01	200	☐	☐	349	
13	0.01	200	☐	☐	349	
14	0.01	200	☐	☐	349	
15	0.01	200	☐	☐	349	

这里是从0开始到11截止，我账户内只有0.1 而这里体现了0.12 也就是提现的进程为12次，369为提现成功，349为提现失败的长度值，从这里就可以看出这个问题的危害了，当然此时账户的金额肯定是为负的了，如果把这个提现金额变大，那么这多提现的金额可不是闹着玩的。

当然，多线程也可以在其他功能处进行测试，比如我之前讲到的试用商品问题，就可以通过多线程进行多几次的使用，比如利用积分总换礼品，一个账户只能进行总换一次，利用这个问题，可以多几次总换，一些转账功能，提现功能，购买功能等等很多。



12.多线程并发

模拟一个场景

从网站去提现金钱

正常请求：用户A在一个网站上提款，发送了提款请求，后台显示一条提款请求，审核了然后顺利提到了。

并发请求：用户A在一个网站上提款，同步发送了多个提款请求，后台显示多条提款请求，审核了然后顺利的提到了几倍的bounty。



Payload Sets

You can define one or more payload sets. The number of payload sets depends on the attack type defined in the Positions tab. Various payload types are available for each payload set, each payload type can be customized in different ways.

Payload set: 1

Payload count: 50

Payload type: Null payloads

Request count: 250



Payload Options [Null payloads]

This payload type generates payloads whose value is an empty string. With no payload markers configured, this can be used to repeatedly issue the base request unmodified.

☒ Generate 50 payloads

☐ Continue indefinitely



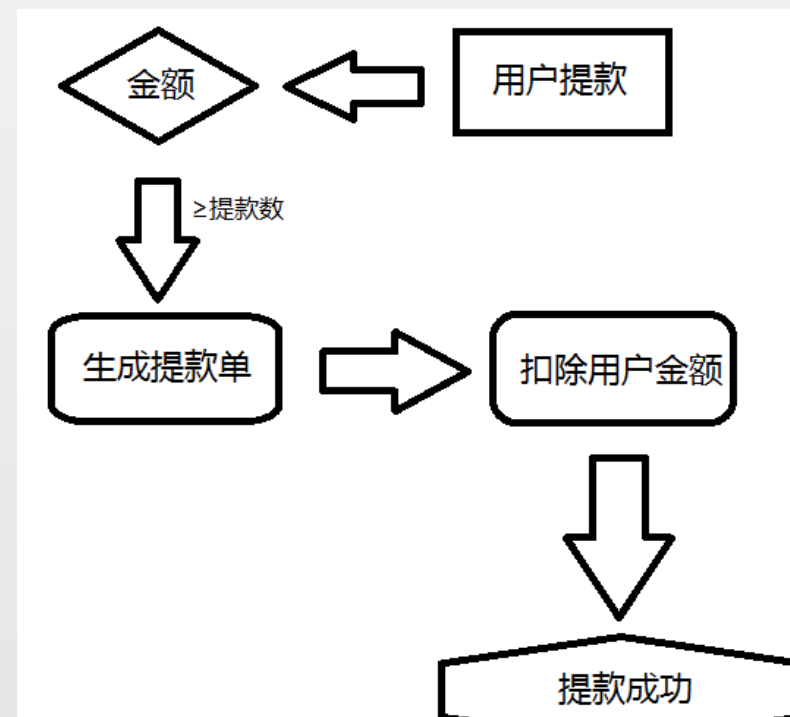
12.多线程并发

- 1.支付
- 2.提款
- 3.退款
- 4.还款等功能。

那么相信大家已经知道要找什么类型的网站：购物、金融网站。

那么到底是哪里出现了问题导致的呢？

我们来看看正常逻辑的处理：





12.多线程并发

如果一个客户同时有两次提款请求，一次提款成功但未扣除金额，另一次提款在第一次提款的基础下扣除了金额，而后台是收到了两次提款请求。

也就是说

当客户的金额只有500元的时候，同时发送多个500元提款请求，但是没有一个请求走到扣除用户金额的位置，多次提款都可以成功，并且后台审核的时候并没发现什么异常

有人可能就会问了，为什么“一次提款成功但未扣除金额”？

其实就是处理速度的问题，数据库的处理速度跟不上用户的请求速度，就有可能存在这样的漏洞。

01 支付漏洞

12.多线程并发（例子）

账户充值

申请提现

提现记录

账户余额：500.0 元

充值金额： 元

支付方式：

☒  支付宝

☐  微信支付

提交

01 支付漏洞

12.多线程并发

收款账户	收款人	提现金额	处理结果
	陈石网络空间安全研究院	¥10.0	待审 [取消]

点击取消提现，抓包，并发测试

您确认取消本次提现吗?

陈石网络空间安全研究院

? **Payload Sets**

You can define one or more payload sets. The number of payload sets depends on each payload type can be customized in different ways.

Payload set: Payload count: 300

Payload type: Request count: 300

? **Payload Options [Null payloads]**

This payload type generates payloads whose value is an empty string. With no pay

☒ Generate payloads

☐ Continue indefinitely



12.多线程并发

Intruder attack 74						
Attack Save Columns						
Results Target Positions Payloads Options						
Filter: Showing all items						
Request	Payload	Status	Error	Timeout	Length	Comment
5	null	200	☐	☐	383	
8	null	200	☐	☐	383	
15	null	200	☐	☐	383	
16	null	200	☐	☐	383	
18	null	200	☐	☐	383	
22	null	200	☐	☐	383	
25	null	200	☐	☐	383	
27	null	200	☐	☐	383	
29	null	200	☐	☐	383	
36	null	200	☐	☐	383	
40	null	200	☐	☐	383	
43	null	200	☐	☐	383	
49	null	200	☐	☐	383	
52	null	200	☐	☐	383	
53	null	200	☐	☐	383	
57	null	200	☐	☐	383	

01 支付漏洞

12.多线程并发

+500.0	500.0	用户取消提现，退回500元
+500.0	500.0	用户取消提现，退回500元
+500.0	500.0	用户取消提现，退回500元
+500.0	500.0	用户取消提现，退回500元
+500.0	500.0	用户取消提现，退回500元

账户余额： 2500.0 元

充值金额： 元

支付方式：☒  支付宝 ☐  微信支付

提交

 支付漏洞思路

网上购物

- 1、选商品
- 2、选规格 ...
- 3、添加购物车 && 直接购买 ...
- 4、填写订单详情（收货地址、是否包邮、是否使用优惠券、是否使用积分、人工服务费等） ...
- 5、确认支付（多接口支付方式、货到付款、他人代付、试用） ...
- 6、订单完成 && 等待收货 && 支付失败 ...
- 7、确认收货 && 拒签 && 退换货 ...
- 8、评论 ...
- 9、追评 ...
- 10、删除订单 ...
- 11、历史订单 ...

 支付漏洞思路

一、订单相关

- 1、选择商品时修改商品价格；
- 2、选择商品时将商品数量设为负数；
- 3、商品剩余1时，多人同时购买，是否产生冲突；
- 4、商品为0时是否还能购买；
- 5、生成订单时修改订单金额；

二、结算相关

- 1、优惠打折活动多次重复使用；
- 2、拦截数据包，修改订单金额；
- 3、拦截数据包，修改支付方式；
- 4、伪造虚假订单，刷单；

三、支付相关

- 1、拦截数据包，伪造第三方确认信息；
- 2、保存用户付款信息被窃取；

四、退货相关

- 1、绕过商家确认直接退货；
- 2、绕过商品类型直接退货；(退货是否允许)
- 3、越权；

五、收货相关

- 1、绕过客户确认直接收货；
- 2、越权；

六、评论相关

- 1、越权；
- 2、信息泄露；
- 3、文件上传；
- 4、sql注入；
- 5、xss；
- 6、刷评论；
- 7、csrf；



感谢您的观看

THANKS FOR YOUR WATCHING